POLICY BRIEF

# WebLock and the EU AI Act: Transparency and Logging in a Fraud-Detection System

*J. Ida Jemi, B.Tech CSE-AI, Indira Gandhi Delhi Technical University for Women · October 2026 · Based on the WebLock repository (README and documented design), github.com/ida-jemi/WebLock. Not legal advice.*

**Summary.** I built WebLock, a graph-based fraud-detection system, and wanted to know how it would fare under the EU AI Act. This brief asks two questions. Would WebLock count as high-risk? And how does it measure up against the Act's logging and transparency requirements? My answer to the first is probably not, because Annex III point 5(b) excludes AI used to detect financial fraud. My answer to the second is that WebLock is reasonably strong on transparency and weak on logging and oversight: I found **4 gaps**. The more interesting point is what the exclusion implies. A customer wrongly flagged by a system like this is protected mainly by the GDPR, not by the AI Act.

## 1. Is WebLock in scope?

Annex III 5(b) lists AI systems used to evaluate the creditworthiness of natural persons, or to establish their credit score, as high-risk, and excludes systems used to detect financial fraud. Recital 58 is consistent with that exclusion. According to DLA Piper's summary of the Commission's draft guidelines on high-risk classification (published 19 May 2026, non-binding), the exclusion is to be read narrowly: fraud detection must be the system's main intended purpose, and the exclusion does not extend to anti-money-laundering checks.

WebLock scores transactions for fraud risk and nothing else, so it most likely sits outside Annex III. Two caveats:

- If a bank fed WebLock's scores into a credit decision, the system would fall back under 5(b).
- Annex III obligations now apply from 2 December 2027 rather than 2 August 2026, under the Digital Omnibus on AI (Regulation (EU) 2026/1744, in force since 27 July 2026). The postponement changes when the rules apply, not what counts as high-risk.

Because WebLock is probably not high-risk, Articles 12 to 15 and 86 do not legally bind it. In the table below I use them as a yardstick for good design.

## 2. WebLock measured against the yardstick

| Provision | What it asks for | What WebLock does | Verdict |
|---|---|---|---|
| **Art. 12** Record keeping | Automatic logging of events over the system's lifetime, so outputs can be traced and monitored (deployers keep logs for at least six months, Art. 26(6)) | `/predict` returns a probability, a risk tier (LOW / MEDIUM / HIGH) and the top 3 contributing factors. The dashboard exports flagged transactions to CSV. Neither is a log of what the system scored, when, and with which model. | **Gap 1** |
| **Art. 13** Transparency | Outputs deployers can interpret, plus instructions for use covering accuracy and limitations | Every score comes with SHAP-based factors in plain language. The README states its limitations openly (proxy entities, batch graph features, no hyperparameter tuning). It is not written as instructions for use: intended purpose and out-of-scope uses are missing. | Partial. **Gap 2** |
| **Art. 14** Human oversight | A design that lets people understand, monitor and override the system | Analysts get a filterable feed, a per-transaction explanation panel and a network view of the flagged account. Nothing records whether the analyst agreed with the flag. | Partial. **Gap 3** |
| **Art. 15** Accuracy and robustness | Declared accuracy and resilience | PR-AUC 0.219 and ROC-AUC 0.810 (baseline: 0.174 and 0.793) on IEEE-CIS, 590,540 transactions, 3.5% fraud, evaluated on a single train/test split. No drift monitoring, robustness checks or subgroup analysis. | Partial. **Gap 4** |
| **Art. 86** Explanation of individual decisions | A clear, meaningful explanation of the role of the system in a decision (applies to deployers of Annex III high-risk systems) | Top-3 SHAP factors per transaction. | Partial, see finding 2 |

## 3. Key findings

1. **The exclusion moves protection from the AI Act to the GDPR.** Where fraud detection sits outside Annex III, a customer blocked on a WebLock score gets none of the Act's logging or explanation rights. The GDPR is what remains. In *SCHUFA* (C-634/21) the CJEU held that a credit reference agency's automated credit score can itself be an automated individual decision under Art. 22 when the lender draws strongly on it. *SCHUFA* concerned credit scores, not fraud scores, but by analogy, if a bank blocked accounts on a HIGH score with no real human review, Art. 22 could be engaged, together with the access right to meaningful information about the logic involved (Art. 15(1)(h)). In *Dun & Bradstreet Austria* (C-203/22) the Court said this means explaining the procedure and principles actually applied in an intelligible way, not handing over a formula. Whether that is enough protection, given that the AI Act's logging duties would not apply, is the question I think a fraud-detection deployer should ask.
2. **A SHAP factor is not the same as an explanation.** SHAP shows which features moved a score, not whether they are a fair basis for it. My own results show why this matters. WebLock's account ID is a proxy (`card1` + `card2` + `addr1`, because IEEE-CIS has no real identity key). Isolated accounts had a higher raw fraud rate (6.9%) than heavily clustered ones (4.0%), which I put down to large clusters being mostly unrelated repeat customers. So a factor like “shared device with 6 other accounts” can look like evidence of a fraud ring when it is partly an artefact of how I built the proxy. Someone flagged on that basis would struggle to contest it, and top-3 SHAP factors alone may fall short of the intelligible account that *Dun & Bradstreet Austria* asks for. This is also a data-quality point (compare Art. 10).
3. **The accuracy numbers are good relative to chance but modest in absolute terms.** A random classifier's PR-AUC is roughly the fraud rate, 0.035, so 0.219 is about six times better than chance, and the graph features lifted PR-AUC by about 25% over the baseline. Even so, an analyst reviewing HIGH-tier alerts should expect many false positives, so human review is necessary, not optional.
4. **Logging is the cheapest gap to close.** Without a record of each prediction, neither Art. 12 traceability nor any later challenge to a decision is possible.

## 4. What I would change

1. Add an append-only audit log for every scoring call: timestamp, model version, hashed transaction ID, score, tier, top factors.
2. Write a model card covering intended purpose, metrics, known limits, and a plain statement that the scores must not feed credit decisions.
3. Let analysts confirm or override a flag, and record that decision.
4. Add drift monitoring and error analysis by segment, and document the limits of the entity proxies.

## Limits of this brief

It assesses WebLock's design as documented in the repository, not a deployed system, and it is not a legal determination. AI Act guidance and timelines are still changing.

*Sources: Regulation (EU) 2024/1689 (Annex III 5(b), Recital 58, Arts. 6, 12-15, 26, 86); Regulation (EU) 2016/679 (GDPR) Arts. 15 and 22; Regulation (EU) 2026/1744 (Digital Omnibus on AI); CJEU C-634/21 SCHUFA Holding (Scoring); CJEU C-203/22 Dun & Bradstreet Austria; DLA Piper alerts on the Commission's draft high-risk classification guidelines (18 June 2026) and the AI Act amendments (1 June 2026); WebLock README.*